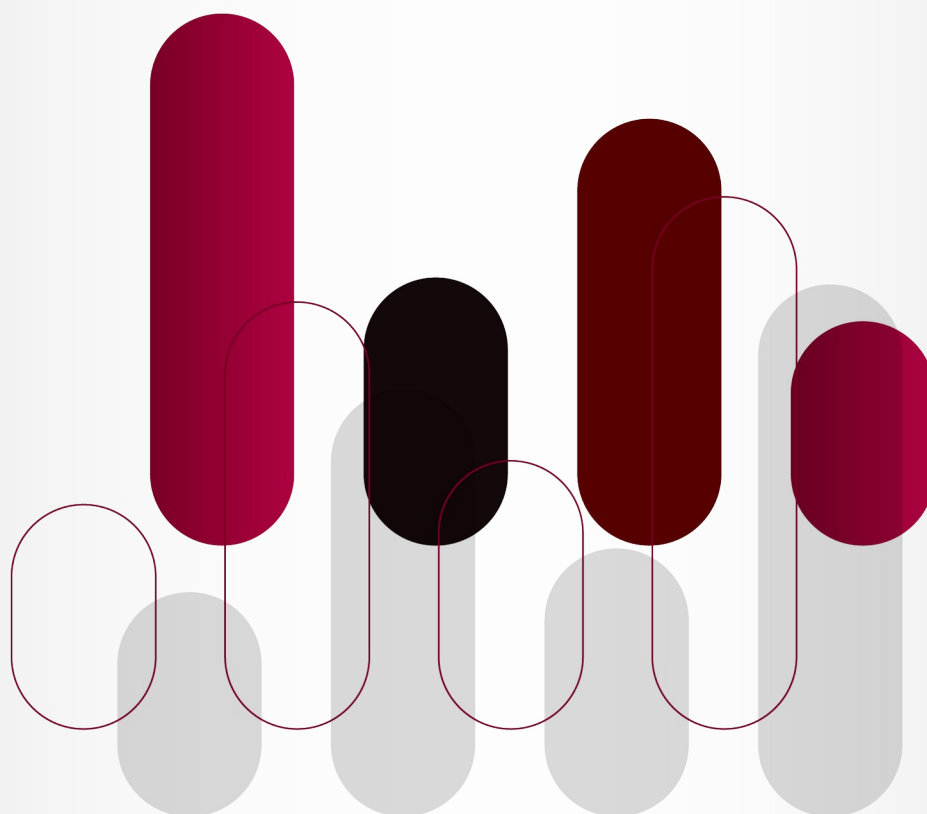




OneBank Head Office Network Internal Penetration Testing Report



**Network Penetration
Testing Report**

Table of Contents

1.0 Document Control.....	1
1.1 Document Details.....	1
1.2 Diffusion List.....	1
1.3 Document History.....	1
2.0 Executive Summary.....	2
2.1 Project Objective.....	2
2.2 Disclaimer.....	3
2.3 Assessment Methodology.....	4
2.4 Summary of iSec Network Penetration Testing Check List.....	5
2.5 Findings Distribution.....	5
2.6 Findings Distribution Chart.....	5
2.7 Risk Criteria.....	6
2.7.1 Exploitation Complexity.....	6
2.7.2 Risk Level Calculation.....	7
2.7.3 Risk Level Calculation.....	7
2.8 Summary of Findings.....	8
3.0 Project Description.....	9
3.1 Scope of work.....	9
3.1.1 Testing Scope.....	9
3.1.2 Provided Credentials.....	9
3.2 Testing Constraints and Limitations.....	10
3.2.1 Initial Test.....	10
3.3 Report Organization.....	10
4.0 Check List.....	11
4.1 iSec Network Penetration Testing Checklist.....	11
4.2 iSec Role in Remediation Phase.....	12
5.0 Vulnerability Findings.....	13
5.1 Head Office Network - Internal Network 10.10.0.0/16.....	13
5.1.1 SMB Signing Not Required on Domain Servers.....	13
Proof Of Concept.....	14
5.1.2 Outdated OpenSSH on the Jump Host.....	15
Proof Of Concept.....	16
5.1.3 SNMP Community String public Enabled.....	17
Proof Of Concept.....	18
6.0 Recommendation.....	19
7.0 Appendix.....	20
7.1 Appendix I: Tools.....	20
7.2 Appendix II: CVSS Scoring Criteria.....	21

1.0 Document Control

1.1 Document Details

Document Title	OneBank Head Office Network Internal Penetration Testing Report v1.0
Document ID	ISEC-NWPT-2026-0042
Classification	Confidential
Description	This document includes technical details of vulnerabilities and their exploits.
Date of Issue	September 22, 2026

1.2 Diffusion List

Contact Name	Contact Title	Contact Email
Ahmed Ali	Chief Information Security Officer	a.ali@onebank.example
Sara Mostafa	Head of Application Security	s.mostafa@onebank.example
Omar Khaled	IT Audit Manager	o.khaled@onebank.example

1.3 Document History

Version	Report Type	Start Date	End Date	Author	Description
1.0	Testing	07/09/2026	18/09/2026	System Administrator	Initial Test
		02/01/2025	02/01/2025	Mona Adel	First Reviewer
		03/01/2025	03/01/2025	Hany Samir	Second Reviewer
		04/01/2025	04/01/2025	Karim Fathy	Approving

2.0 Executive Summary

2.1 Project Objective

iSec performed **Initial Test Grey box** an Internal network penetration testing on Head Office Network. The purpose of this security assessment is to identify the application vulnerabilities and weakness. iSec's penetration testers adhere to a structured methodology, drawing inspiration from industry-standard frameworks, including but not limited to Open-Source Security Testing Methodology Manual (OSSTMM), Penetration Testing Execution Standard (PTES), and NIST (National Institute of Standards and Technology).

This flexible methodology ensures a thorough examination of potential risks, allowing for tailored assessments based on specific client needs and encompassing broader industry best practices. Responding to a client request, the penetration testing engagement was initiated during working hours.

This strategy will imitate an attacker's tactics by making use of many of the same easily available tools such as Nmap, Metasploit, Burp suite, and more. As the process unfolds, we plan to dive deeper, incorporating more advanced techniques to identify additional attack surfaces.

iSec's approach to this security testing was meticulously conducted through extensive manual testing procedures, along with the use of automated tools and report the findings at the end of the engagement. The assessment seeks to enhance the overall security of the web application through various objectives. These include conducting vulnerability scanning, improving access controls, ensuring robust authentication and session management, and addressing potential weaknesses that could compromise the confidentiality of information. Collectively, these efforts aim to fortify the application against a range of security risks.

The results presented in this report represent the situation in a limited time frame. Any changes in the current architecture, code, and/or configurations might lead to different results if the test is to be conducted again.

Because of the time limitation and the nature and sensitivity of the tested servers, some exploitation techniques were excluded. This penetration test does not include:

- Social Engineering attacks
- Denial-of-Service attacks

2.2 Disclaimer

This report contains confidential information that is intended only for **OneBank**. We hereby disclaim all liability for any damages resulting from third-party alterations and prohibit any unauthorized use, disclosure, or copying.

Due to timing limitations, not every security measure was thoroughly assessed. The findings, recommendations, and risks are current as of the time of submission and are based on the data gathered during the assessment; they might not be updated to reflect recent developments.

The allocated man-days for testing directly impact the findings. Increasing the time allocated for testing enhances the likelihood of identifying a greater number of findings, as more time allows for a more thorough and comprehensive assessment.

This report's future projections could change as a result of modifications to the infrastructure architecture. The use of the stated targeted applications or systems may result in financial loss to the respected company, and the report makes no guarantees regarding this matter. iSec is not absolute, and policy reviews, upkeep, and regular monitoring are essential.

iSec provides no warranties, representations, or legal certifications for tested applications or systems.

2.3 Assessment Methodology

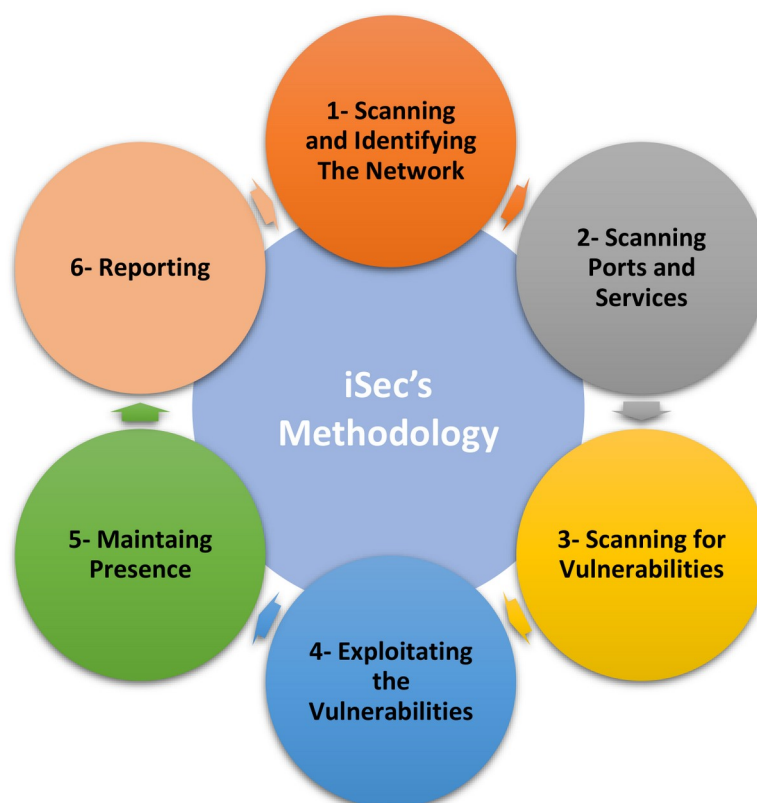
iSec's methodology, our penetration testers adhere to a structured methodology, drawing inspiration from industry-standard frameworks, including but not limited to the **Open-Source Security Testing Methodology Manual (OSSTMM)**, **Penetration Testing Execution Standard (PTES)**, and **NIST (National Institute of Standards and Technology)**. This flexible methodology ensures a thorough examination of potential risks, allowing for tailored assessments based on specific client needs and encompassing broader industry best practices. This strategy will imitate an attacker's tactics by making use of many of the same easily available tools.

Initially, it involves information gathering and threat modeling to understand the target application's architecture, potential vulnerabilities, and collect data related to the target scope. Subsequently, we move on to exploiting identified vulnerabilities uncovered during the preliminary steps. This involves a meticulous examination of user information, scrutinizing permissions, and assessing potential risks associated with unauthorized access to restricted paths.

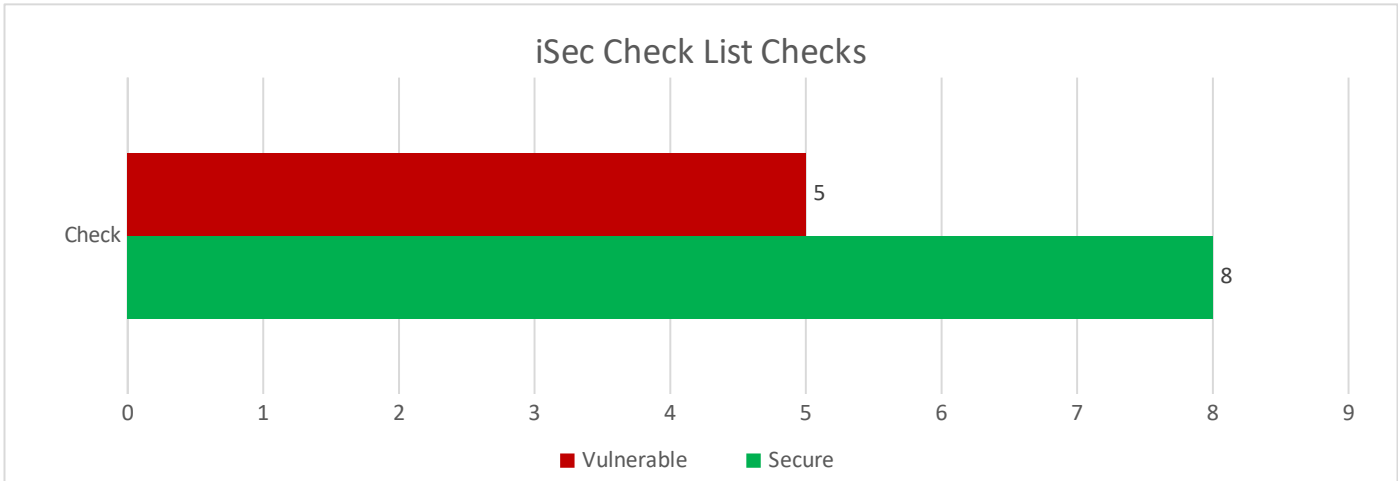
The actual testing phase includes vulnerability scanning, manual testing, and exploitation to validate identified issues. Throughout the process, adherence to industry-standard frameworks ensures comprehensive coverage of testing scenarios, including authentication, authorization, input validation, and data security.

Finally, the findings are documented, providing clear and actionable recommendations for remediation, prioritized based on risk severity to assist in securing the network effectively.

By systematically progressing through these steps, we ensure a thorough and methodical assessment, adhering to industry best practices and security standards.



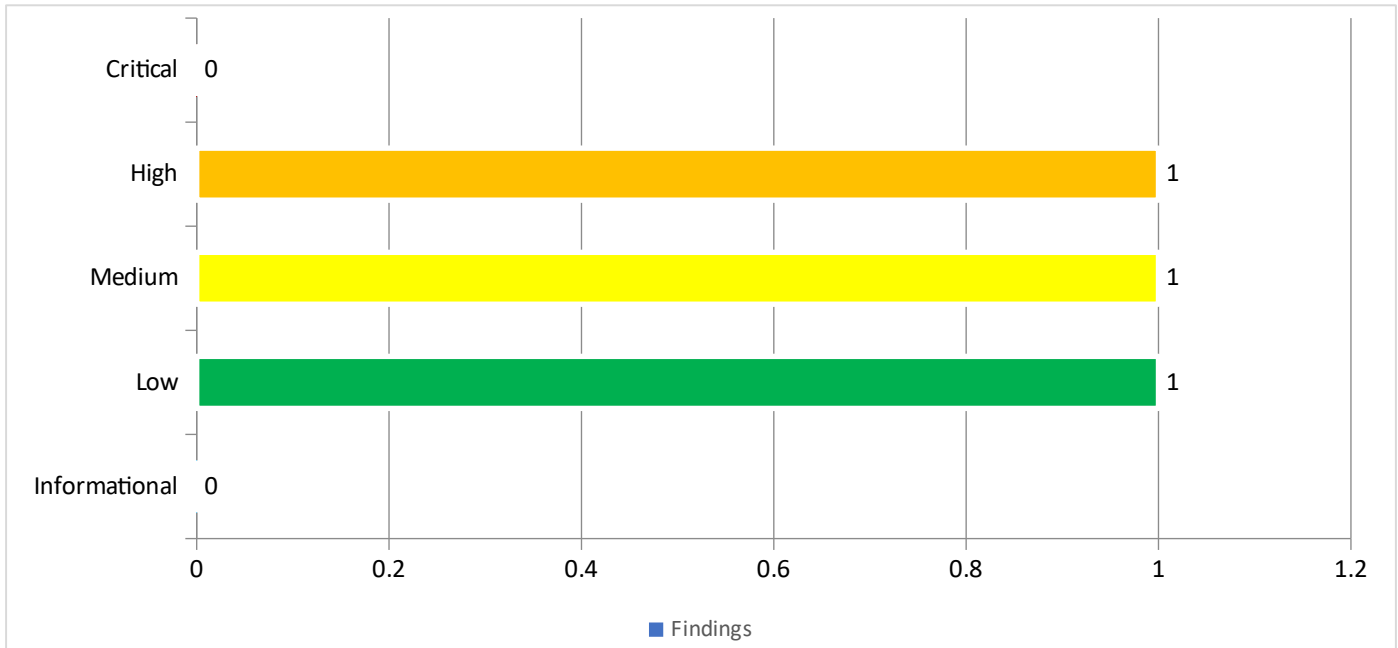
2.4 Summary of iSec Network Penetration Testing Check List



2.5 Findings Distribution

Severity	Initial Test
Critical	0
High	1
Medium	1
Low	1
Informational	0

2.6 Findings Distribution Chart



2.7 Risk Criteria

Each finding identified in this security assessment is rated against both the impact of the finding and how easy it would be for an attacker to exploit. The fix rating provides a guide to the effort required to resolve the finding. Type specifies in which Classification type the finding comes under. The overall rating for the finding is calculated based on the finding's impact and ease ratings.

Semiquantitative	CVSS	Description
Critical	9.0 - 10.0	The vulnerability is exposed and exploitable, and its exploitation could result in severe impacts. Relevant security control or other remediation is not implemented and not planned; or no security measure can be identified to remediate the vulnerability.
High	7.0 - 8.9	The vulnerability is of high concern, based on the exposure of the vulnerability and ease of exploitation and/or on the severity of impacts that could result from its Relevant security control or other remediation is planned but not implemented; compensating controls are in place and at least minimally effective.
Medium	4.0 - 6.9	The vulnerability is of moderate concern, based on the exposure of the vulnerability and ease of exploitation and/or on the severity of impacts that could result from its Relevant security control or other remediation is partially implemented and somewhat effective.
Low	0.1 - 3.9	The vulnerability is of minor concern, but effectiveness of remediation could be improved. Relevant security control or other remediation is fully implemented and somewhat effective.
Informational	0.0	The vulnerability is not of concern. Relevant security control or other remediation is fully implemented, assessed, and effective.

2.7.1 Exploitation Complexity

Value	Description
Complex	An attacker with an advanced knowledge and reasonable experience with a lot of effort and personal developed tools/scripts can exploit this vulnerability.
Moderate	An attacker with some specific knowledge using a combination of automated tools, operating system tools and open-source tools can exploit this vulnerability.
Easy	An attacker with minimal or basic knowledge depending on automated tools or open-source tools can exploit this vulnerability.
Trivial	Anyone with no knowledge with the help of an automated tool can exploit this vulnerability.

2.7.2 Risk Level Calculation

Complexity Impact	Trivial	Easy	Moderate	Complex
Critical	Critical	Critical	High	High
High	Critical	High	High	Medium
Medium	High	Medium	Medium	Low
Low	Medium	Medium	Low	Low

2.7.3 Risk Level Calculation

		Impact How severe would the outcomes be if the risk occurred? →				
		Insignificant 1	Minor 2	Significant 3	Major 4	Severe 5
Probability What is the probability the risk will happen?	Rare 1	Very Low 1	Very Low 2	Low 3	Medium 4	Medium 5
	Unlikely 2	Very Low 2	Low 4	Medium 6	Medium 8	High 10
	Moderate 3	Low 3	Medium 6	Medium 9	High 12	Very High 15
	Likely 4	Medium 4	Medium 8	High 12	Very High 16	Extreme 20
	Almost Likely 5	Medium 5	High 10	Very High 15	Extreme 20	Extreme 25

2.8 Summary of Findings

The below table determine the summary of penetration testing final result.

#	Vulnerability	Risk	CVSS 3.1	Affected URL	Affected User	Status
1.	SMB Signing Not Required on Domain Servers	High	8.1	10.10.1.15, 10.10.1.16, 10.10.1.22	Domain users	Initial Test
2.	Outdated OpenSSH on the Jump Host	Medium	5.3	10.10.5.10:22	-	Initial Test
3.	SNMP Community String public Enabled	Low	3.7	10.10.1.1	-	Initial Test

3.0 Project Description

3.1 Scope of work

This penetration testing **Initial Test** was conducted on **Head Office Network** as a **Grey Box** penetration test, aimed at evaluating the effectiveness of the security features and controls implemented on the application. Consequently, the resulting report will provide an overview of the current security state of the program, detailing the identified vulnerabilities along with recommended security mitigations. By assigning risk ratings to each vulnerability, the management will be empowered to make informed decisions regarding the appropriate measures to address the identified risks.

- This Penetration Testing on **Head Office Network** was done on a **Production Environment**.

3.1.1 Testing Scope

In Scope IPs			
• 10.10.1.1 • 10.10.1.10 • 10.10.1.15 • 10.10.1.16 • 10.10.1.22 • 10.10.1.30 • 10.10.1.31 • 10.10.1.40 • 10.10.1.41 • 10.10.1.50	• 10.10.20.1 • 10.10.20.10 • 10.10.20.11 • 10.10.20.12 • 10.10.20.13 • 10.10.20.14 • 10.10.20.15 • 10.10.20.20 • 10.10.20.21 • 10.10.20.25	• 10.10.5.10 • 10.10.5.11 • 10.10.5.12	
Out Of Scope IPs and Ports			
Functions Names		Reason	
• 10.10.3.0/24 • 10.10.4.0/24		• Requested by client (OT segment) • Out of contract scope	

3.1.2 Provided Credentials

User	Description
• svc_pentest • audit_ro	• Domain user, no admin rights • Read-only account on the jump host

3.2 Testing Constraints and Limitations

3.2.1 Initial Test

Rate limiting on the perimeter firewall slowed host discovery on 10.10.20.0/24; the client whitelisted the tester's address on the second day.

3.3 Report Organization

This report is organized into six sections, as follows:

Section	Description
Executive Summary	Introductory section targeting non-technical management.
Project Description	Describing the project scope and objective.
Methodology & checklist	Describing the assessment methodology & checklist.
Detailed findings	Detailed low-level findings for each system within the scope.
Attack Scenarios	Details of the assessment scenarios.
Conclusion	Summary of recommendation and suggested way forwards.

4.0 Check List

4.1 iSec Network Penetration Testing Checklist

#	Attack Type	Done	Status
1.	Brute Force/Spraying	N/A	N/A
2.	WAF & Firewall Bypass	Done	Not Vulnerable
3.	Sensitive Data Enumeration	Done	Not Vulnerable
4.	Injectons	Done	Not Vulnerable
5.	Weak configuration or Misconfiguration	Done	Not Vulnerable
6.	Sensitive Data Exposure	Done	Vulnerable
7.	Privilege Escalation	Done	Not Vulnerable
8.	Lateral Movement	Done	Vulnerable
9.	Remote Code Execution	Done	Not Vulnerable
10.	Outdated Services & Components	Done	Not Vulnerable
11.	Buffer Overflow	Done	Not Vulnerable
12.	Cryptography Failures	Done	Not Vulnerable
13.	Default Credential	Done	Not Vulnerable

4.2 iSec Role in Remediation Phase

Penetration testing evaluates an organization's ability to protect its networks, applications, endpoints and users from attempts to circumvent its security controls to gain unauthorized or privileged access to protected assets. Test results validate the risk posed by specific security vulnerabilities or flawed processes, the results will be communicated to the involved teams in a way that allows team to more intelligently prioritize remediation, apply needed security patches and allocate security resources more efficiently to ensure that they are available when and where they are needed most. iSec team is committed to clearly communicate the findings and recommended counter measures to all parties responsible for the remediation. iSec team will provide the required support to team while implementing the recommended remediation activities.

5.0 Vulnerability Findings

5.1 Head Office Network - Internal Network 10.10.0.0/16

5.1.1 SMB Signing Not Required on Domain Servers

Severity	CVSS 3.1	Status
High	8.1 (View CVSS Metrics)	Initial Test
Affected Assets	10.10.1.15, 10.10.1.16, 10.10.1.22	
iSec Check List	Lateral Movement, Weak configuration or Misconfiguration	
Description	SMB signing is not enforced on three domain servers, so an attacker on the same segment can relay NTLM authentication to them.	
Impact	Relayed authentication gives an attacker local administrator access on the file servers and a path to domain compromise.	
Recommendation	Enable Microsoft network server: Digitally sign communications (always) through Group Policy on all servers.	

Proof Of Concept

Step 1: Responder captured an NTLMv2 authentication from a workstation.

Step 2: ntlmrelayx relayed it to 10.10.1.15 and dumped the local SAM.

Host	Signing
10.10.1.15	disabled
10.10.1.16	disabled

```
ntlmrelayx.py -t smb://10.10.1.15 -smb2support
```


5.1.2 Outdated OpenSSH on the Jump Host

Severity	CVSS 3.1	Status
Medium	5.3 (View CVSS Metrics)	Initial Test
Affected Assets	10.10.5.10:22	
iSec Check List	Outdated Services & Components	
Description	The jump host runs OpenSSH 7.4, which has several published vulnerabilities.	
Impact	Known weaknesses in this release can leak user names and, in some configurations, allow authentication bypass.	
Recommendation	Update OpenSSH to the latest vendor-supported release.	

Proof Of Concept

Step 1: The banner returned SSH-2.0-OpenSSH_7.4.

Step 2: The version was matched against the CVE list.

5.1.3 SNMP Community String public Enabled

Severity	CVSS 3.1	Status
Low	3.7 (View CVSS Metrics)	Initial Test
Affected Assets	10.10.1.1	
iSec Check List	Default Credential, Sensitive Data Enumeration	
Description	The core switch answers SNMP v2c queries with the default community string.	
Impact	Device configuration and topology details are exposed to anyone on the network.	
Recommendation	Disable SNMP v2c and use SNMPv3 with authentication and privacy.	

Proof Of Concept

Step 1: snmpwalk with community public returned the full interface table.

6.0 Recommendation

The following actions are recommended for you to improve the current security.

- Cover all the findings stated in this report.
- Segment the server VLAN from the user VLAN.
- Retire SMBv1 and enforce SMB signing on every host.

7.0 Appendix

7.1 Appendix I: Tools

This appendix outlines the various tools used throughout the assessment.

Tool	Purpose
Nmap	Nmap is used to discover hosts and services on a computer network and operating system detection. by sending packets and analyzing the responses.
Acunetix	Acunetix web vulnerabilities, Acunetix aimed to offer an automated tool to scan web applications to identify and resolve security issues. Simply put, Acunetix is an all-in-one website security scanner.
Burp suite professional	Burp Suite is an integrated platform/graphical tool for performing security testing of web applications. Its various tools work seamlessly together to support the entire testing process, from initial mapping and analyzing of an application's attack surface, discover findings and exploiting security vulnerabilities.
Ffuf	Ffuf is a fast web fuzzer written in Go that allows typical directory discovery, virtual host discovery (without DNS records) and GET and POST parameter fuzzing.
Nuclei	Nuclei is used to send requests across targets based on a template, leading to zero false positives and providing fast scanning on a large number of hosts. Nuclei offers scanning for a variety of protocols, including TCP, DNS, HTTP, SSL, File, Whois, Websocket, Headless etc. With powerful and flexible templating, Nuclei can be used to model all kinds of security checks.

7.2 Appendix II: CVSS Scoring Criteria

This appendix outlines the CVSS base scores calculations.

Impact Metrics	Description
Confidentiality Impact (C)	Represents the impact on confidentiality, with values None (N), Low (L), or High (H).
Integrity Impact (I)	Describes the impact on integrity, with values None (N), Low (L), or High (H).
Availability Impact (A)	Indicates the impact on availability, with values None (N), Low (L), or High (H).

Exploitability Metrics	Description
Attack Vector (AV)	Describes how the vulnerability is exploited, ranging from Local (L) to Network (N) attacks.
Attack Complexity	Specifies the complexity of the attack required, from Low (L) to High (H).
Privileges Required (PR)	Defines the privileges an attacker needs, ranging from None (N) to High (H).
User Interaction (UI)	Indicates whether user interaction is required, with values None (N) or Required (R).

The Base Score is calculated using the formula:

This formula combines the Impact and Exploitability metrics, ensuring a comprehensive evaluation of the vulnerability's severity. The Base Score provides a standardized way to prioritize security efforts, enabling organizations to effectively manage their vulnerabilities.

An online CVSS Calculator tool is used to perform the calculation: <https://nvd.nist.gov/vuln-metrics/cvss/v3-calculator>

